

QCM Complété – Normes & Standards de Cybersécurité (36 questions)

1. Quel est l'objectif principal d'une norme de cybersécurité ?

- A. Augmenter les performances réseau
- B. Harmoniser les pratiques et améliorer la sécurité
- C. Remplacer les outils existants
- D. Supprimer les incidents

2. La norme ISO 27001 repose principalement sur :

- A. La création d'antivirus
- B. Un Système de Management de la Sécurité de l'Information
- C. L'audit financier
- D. La gestion réseau

3. Quel document décrit les mesures de sécurité associées à ISO 27001 ?

- A. ISO 27005
- B. ISO 27002
- C. ISO 27701
- D. ISO 31000

4. ISO 27005 traite principalement de :

- A. Gestion du risque
- B. Cryptographie
- C. Gestion des incidents
- D. Sécurité du cloud

5. Le NIST Cybersecurity Framework comporte combien de fonctions principales (en plus de la fonction Govern) ?

- A. 3
- B. 4
- C. 5
- D. 7

6. Quelle est la première fonction du NIST CSF ?

- A. Detect
- B. Identify
- C. Protect
- D. Recover

7. Les CIS Controls sont :

- A. Des lois internationales
- B. Des bonnes pratiques techniques prioritaires
- C. Un logiciel antivirus
- D. Un outil de certification

8. Le Top 10 de l'OWASP concerne :

- A. Les principales vulnérabilités applicatives
- B. Les failles de réseaux industriels
- C. Les menaces IoT
- D. Les politiques GDPR

9. MITRE ATT&CK est (BONUS) :

- A. Une norme ISO
- B. Une base de connaissance des tactiques d'attaque
- C. Une loi américaine
- D. Un protocole réseau

10. Le référentiel PCI-DSS s'applique :

- A. Aux données médicales
- B. Aux cartes bancaires et paiements
- C. Aux systèmes industriels
- D. Aux données des réseaux sociaux

11. Le RGPD vise à protéger :

- A. Les données marketing
- B. Les données personnelles des citoyens européens
- C. Les données militaires
- D. Les données financières des banques

12. Le délai légal pour notifier une violation de données au titre du RGPD est :

- A. 12 h
- B. 72 h
- C. 7 jours
- D. 1 mois

13. La directive NIS/NIS2 concerne (BONUS) :

- A. La protection des écoles
- B. Les opérateurs de services essentiels et entités critiques
- C. Les réseaux sociaux
- D. Les utilisateurs individuels

14. La norme ISO 27701 traite de :

- A. La sécurité physique
- B. La protection de la vie privée
- C. Le cloud computing
- D. La cryptographie avancée

15. La norme ISO 27018 traite de :

- A. La protection des données dans le cloud
- B. Les réseaux industriels
- C. Les réseaux Wi-Fi
- D. Les attaques web

16. Le Cybersecurity Framework (CSF) est publié par :

- A. OWASP
- B. CSA (Cloud Security Alliance)
- C. Microsoft
- D. NIST

17. Le standard IEC 62443 s'applique à (BONUS) :

- A. La sécurité des systèmes industriels (OT)
- B. La sécurité du web
- C. La sécurité des emails
- D. Le développement logiciel

18. Un avantage majeur des normes est :

- A. Elles garantissent que les attaques cessent
- B. Elles permettent d'harmoniser les pratiques et prouver la conformité
- C. Elles remplacent les outils existants
- D. Elles suppriment le besoin de compétences humaines

19. Le SMSI (dans ISO 27001) repose sur quel cycle ?

- A. LEAN
- B. PDCA
- C. Cascade
- D. Big Bang

20. Une certification ISO 27001 signifie :

- A. Que l'entreprise ne sera plus piratée
- B. Que l'entreprise applique un SMSI conforme à la norme
- C. Que l'entreprise utilise des outils approuvés
- D. Que tous les employés sont experts cybersécurité

21. Le Zero Trust repose sur :

- A. Tout le monde est fiable
- B. Toujours vérifier, ne jamais faire confiance
- C. Un seul contrôle d'accès suffit
- D. Les réseaux internes sont toujours sûrs

22. Les audits basés sur une norme permettent :

- A. De vérifier la conformité à un référentiel reconnu
- B. De remplacer les équipes sécurité
- C. De gagner du temps sur les contrôles
- D. De supprimer les engagements contractuels

23. Les standards facilitent la collaboration car :

- A. Ils imposent le même matériel
- B. Ils définissent des pratiques communes
- C. Ils imposent le même OS
- D. Ils standardisent les logos

24. Le RGPD repose sur le principe de :

- A. Minimisation des données
- B. Collecte illimitée
- C. Conservation permanente
- D. Transfert automatique des données

25. Quel est l'objectif principal d'ISO 27005 ?

- A. Décrire les contrôles de sécurité
- B. Structurer la gestion des risques de sécurité
- C. Définir les mesures techniques de chiffrement
- D. Imposer une analyse financière

26. La première étape d'une analyse de risques selon ISO 27005 est :

- A. Le traitement du risque
- B. L'identification des actifs
- C. Le choix du firewall
- D. La rédaction du rapport final

27. ISO 27005 distingue principalement :

- A. Menaces, vulnérabilités et impacts
- B. Firewall, antivirus et proxy
- C. Réseau, application et cloud
- D. RGPD, NIS2 et PCI-DSS

28. Le risque est généralement défini comme :

- A. Une faille informatique
- B. La combinaison probabilité $\times$ impact
- C. Un simple bug logiciel
- D. Une mesure de conformité

29. Quel est l'objectif du traitement des risques ?

- A. Les supprimer totalement
- B. Les réduire à un niveau acceptable
- C. Les transférer systématiquement
- D. Les ignorer s'ils sont faibles

30. Quel livrable est typique de la démarche ISO 27005 ?

- A. Un rapport annuel ESG
- B. Une cartographie des risques
- C. Un organigramme RH
- D. Un plan marketing

31. À quoi sert la certification HDS ?

- A. À protéger les données bancaires
- B. À encadrer l'hébergement sécurisé des données de santé
- C. À contrôler les réseaux industriels
- D. À certifier les sites e-commerce

32. Le référentiel HDS concerne :

- A. Toute entreprise stockant des données personnelles
- B. Les organismes manipulant des données de santé
- C. Uniquement les hôpitaux publics
- D. Les entreprises américaines

33. Combien de périmètres d'activités comprend la certification HDS ?

- A. 2
- B. 4
- C. 6
- D. 8

34. Le référentiel HDS impose :

- A. Un SMSI conforme à ISO 27001
- B. Un simple antivirus obligatoire
- C. Une connexion VPN pour tous
- D. Un stockage uniquement en local

35. Les exigences HDS s'appuient notamment sur :

- A. ISO 9001
- B. ISO 27001 et ISO 20000
- C. OWASP SAMM
- D. CIS Controls

36. Le référentiel HDS est rédigé par :

- A. L'ANSSI
- B. l'ANS
- C. L'Afnor
- D. L'OMS

38. Quelle organisation est à l'origine de PCI DSS ?

- A. L'Union Européenne
- B. Le Payment Card Industry Security Standards Council
- C. L'ONU
- D. Le NIST

39. PCI DSS impose notamment :

- A. Le cryptage des données de carte
- B. L'utilisation obligatoire d'un seul fournisseur cloud
- C. La suppression des journaux de logs
- D. Le stockage illimité des données bancaires

40. Qui doit se conformer à PCI DSS ?

- A. Uniquement les banques
- B. Toute organisation traitant, stockant ou transmettant des données de carte
- C. Les hôpitaux
- D. Les opérateurs téléphoniques

41. EBIOS RM est une méthode qui sert à :

- A. Développer des logiciels
- B. Analyser et traiter les risques de sécurité
- C. Réparer les incidents réseaux
- D. Créer des politiques GDPR

42. Combien d'ateliers structurent la méthode EBIOS RM ?

- A. 2
- B. 3
- C. 5
- D. 7

43. L'atelier « Cadrage et socle de sécurité » permet de :

- A. Déployer un firewall
- B. Définir le périmètre et les objectifs de l'étude de risque
- C. Classer les employés
- D. Installer des outils SIEM

44. L'atelier « Étude des chemins d'attaque » vise à identifier :

- A. Les virus courants
- B. Les scénarios d'attaque exploitant des vulnérabilités
- C. Les fournisseurs cloud
- D. Les outils de chiffrement disponibles

45. Le concept clé d'EBIOS RM est :

- A. Le principe de Zero Trust
- B. Le scénario de risque
- C. Le chiffrement asymétrique
- D. Les mots de passe à usage unique

46. L'atelier « Traitement des risques » permet de :

- A. Définir les mesures de sécurité pour réduire les risques
- B. Développer un antivirus
- C. Créer un plan de marketing
- D. Tester des câbles réseau